PCI_DSS & HIPAA

ASSIGNMENT

Governance Risk and Compliance (GRC)

Analyst: Maureen Uzoewulu

September 4, 2026

Table of Contents

Table of Contents 1
Case Study: Nexus Health Services 2
Introduction 2
Task Checklist 2
Executive Summary 3
Business Scope: Which Processes Are Critical 4
The Data Map: What Sensitive Information Exists and Where It Flows 5
Compliance Scope: Where PCI DSS and HIPAA Apply 7
Risk Map: What Could Go Wrong 8
Controls: Which Requirements Address the Risks 10
Evidence Plan: What Proves the Controls Work 13
Prioritized Remediation Plan 16
The Management Message: Top Three Risks Explained 19
References 20

Case Study: Nexus Health Services

Introduction

Nexus Health is a multi-site healthcare organization operating hospitals, outpatient clinics, and diagnostic centers. As part of its patient care and billing operations, Nexus Health accepts payment cards for consultations, procedures, diagnostic tests, and outstanding balances, both in person and through an online patient portal. Because Nexus Health stores, processes, and transmits cardholder data, it falls squarely within the scope of the Payment Card Industry Data Security Standard (PCI DSS) in addition to its obligations under HIPAA for Protected Health Information (PHI/ePHI).

Management: "We need to demonstrate that Nexus is adequately protecting payment card data and health information." You have 15 minutes.

- 1–2. Business Scope & Data Map

What processes are critical, and what sensitive information exists?

- 3–4. Compliance Scope & Risk Map

Where does PCI DSS / HIPAA apply, and what could go wrong?

- 5–8. Controls, Evidence, Remediation & Message

Which requirements address the risks, what evidence proves it, what gets fixed first, and how would you explain the top three risks to the CEO?

Task Checklist

1. Map business scope
2. Build the data map
3. Determine PCI & HIPAA scope
4. Map risks to requirements
5. Build an evidence plan
6. Prioritize the remediation plan
7. Prepare the management message

Executive Summary

Nexus Health Services is a multi-site healthcare organization operating hospitals, outpatient clinics, and diagnostic centers that accepts payment cards in person and through an online patient portal, placing it simultaneously within the PCI DSS scope for cardholder data and the HIPAA scope for PHI/ePHI. Nexus cannot yet demonstrate adequate protection, because five confirmed gaps – weak privileged authentication, unreviewed security logs, a healthcare vendor operating without a Business Associate Agreement, an unvalidated compliance scope, and an untested incident-response process – mean controls are documented but not evidenced as operating.

Compliance in this context is the chain from what Nexus does, to what data it handles, to what can go wrong, to which requirements apply, to which controls exist, to whether those controls work, to how they are continuously improved. The deliverable below follows that chain across the eight assignment steps.

A single framework cannot cover both obligations. PCI DSS protects payment account data, which this organization could validate through ROC (Report on Compliance) pathways, while HIPAA protects PHI/ePHI through Administrative, Physical, and Technical Safeguards enforced by the HHS Office for Civil Rights. The correct strategy is a common control layer with two separate data scopes – one control (for example, MFA or quarterly access review) mapped to both a PCI DSS requirement code and a HIPAA Security Rule citation, with evidence filed against the control rather than the framework.

Business Scope: Which Processes Are Critical

Five processes are critical to Nexus because each one creates, receives, maintains or transmits regulated data, and each carries a distinct business impact.

Table 1: Business scope

Business Processes	Why it is Critical	Business Impact
Payment processing (in-person POS + online patient portal)	Only process that authorizes and settles card transactions.	Financial loss, card-brand fines, loss of ability to accept cards
Healthcare billing and claims	Combines clinical/treatment data with billing and insurance data.	Privacy breach, OCR (Office for Civil Rights) investigation
Customer/patient support (contact centre, CRM)	Agents handle identity, account and health queries and may take card details verbally.	Unauthorized disclosure of PHI
Account management (banking platform, refunds, balances)	Holds financial and identity data and settlement instructions.	Fraud
Vendor / third-party management (cloud, billing bureau, payment gateway)	External parties access regulated data on Nexus's behalf.	Third-party risk, PHI mishandling, inherited breach

The Data Map: What Sensitive Information Exists and Where It Flows

The data map answers four questions per process: what data, which system, where it goes, and who can access it.

Table 2: Data Map

Process	Data Type and Elements	System	Where It Goes	Who Can Access It
Payment processing	Cardholder Data: PAN (primary account number), expiry, cardholder name; sensitive authentication data (CVV, PIN)	POS, Patient Portal, Payment Gateway	Processor → Merchant Bank → Nexus Finance	Cashiers, Billing, Finance, IT admins, Processor staff
Healthcare billing	PHI / ePHI (Patient identifiers, diagnoses/treatment codes)	EHR, Billing System, CRM, Cloud Provider	Claims processors, insurers, vendors	Clinicians, Billing, Support, IT, Vendors (Business Associate Agreement - BAA)
	Billing Data (insurance information, billing information)	Billing System, EHR	Insurers, finance systems	Billing staff, Finance, IT
Customer support	Customer identity Data, account data,	CRM, Patient Portal	Support workflows, account management	Support agents, CRM admins

	call recordings and screen captures that may contain both PHI and card data			
Account management	Financial Account Data (Bank account details, balances, refund and settlement records)	Banking Platform	Bank → Nexus Finance	Finance, Accounting, Bank personnel
Vendor management	Vendor Data (Contracts, BAAs, AOCs, vendor contact and access records)	Vendor Portal, Contract Repository	Vendors → Subcontractors	GRC Team, Legal, Vendor staff

Compliance Scope: Where PCI DSS and HIPAA Apply

Scope is determined by two independent tests applied to every process, system and vendor identified above. The two scoping tests are:

PCI DSS test: Does this process store, process or transmit payment account data? If yes, investigate PCI DSS scope.

In Scope:

- Payment platform
- POS terminals
- Online payment portal
- Any system connected to the Cardholder Data Environment (CDE)

HIPAA test: Does Nexus create, receive, maintain or transmit PHI/ePHI, either as a covered entity or on behalf of one? If yes, investigate HIPAA applicability.

In Scope:

- Billing system
- EHR/Clinical systems
- CRM
- Vendors handling PHI (BAA required)

Risk Map: What Could Go Wrong

Each risk below is derived from the control gaps stated in the case study. The ratings are qualitative assessments based on the scenarios and business impacts.

Table 3: Risk Assessment

ID	Scenario	Risk/What could go wrong	Likelihood	Impact	Rating
R1	Privileged users lack strong authentication controls	Stolen or misused credentials could allow unauthorized access to payment systems and sensitive information	High	Severe	Critical
R2	Security logs exist, but nobody reviews them	Delayed detection of unauthorized activity; breach dwell time extends, and notification is delayed	High	Severe	Critical
R3	Healthcare vendor operates without a documented BAA	The vendor may use, disclose or fail to protect PHI without clearly defined contractual responsibilities	Medium	Severe	High
R4	PCI DSS and HIPAA compliance scope incomplete/unvalidated	Nexus may exclude systems, processes or vendors that store, process, receive, maintain or transmit regulated information	High	High	High

R5	Incident-response process unclear and untested	Employees may not know how to contain, investigate, escalate or recover from an incident	Medium	High	High
R6	Laptop or mobile device containing ePHI lost in public	An unauthorized person could physically obtain the device and access patient information	Medium	High	High
R7	Stored or transmitted payment account data is not adequately protected	An attacker or unauthorized employee could read or disclose cardholder data	Medium	Severe	High
R8	Policy exists but staff do not follow it	Controls may appear compliant on paper while failing in practice	Medium	High	High

Controls: Which Requirements Address the Risks

The 12 PCI DSS requirements are the actionable steps behind six control objectives:

- secure network and systems (1 and 2),
- protect account data (3 and 4),
- vulnerability management (5 and 6),
- access control (7 to 9),
- monitor and test (10 and 11), and
- security policy (12).

HIPAA organizes the equivalent expectations into Administrative, Physical and Technical Safeguards, with technical safeguards covering access control, audit controls, integrity, person-or-entity authentication and transmission security.

Table 4: Risk-to-requirement mapping and controls

Risk	PCI DSS requirement	HIPAA requirement or safeguard	Control Nexus should implement
R1: Weak authentication	**Requirement 7:** Restrict access by business need-to-know. **Requirement 8:** Identify users and authenticate access	**Technical Safeguards:** Access Control and Authentication	Assign each user an individual account, restrict access according to job responsibilities, strengthen authentication, apply MFA to privileged and sensitive-system access, and regularly review access rights.
R2: Poor log review	**Requirement 10:** Log and monitor all access.	**Technical Safeguards:** Audit Controls.	Centralize security logs, assign the SOC responsibility for

	Requirement 11: Regularly test security systems and processes	**Administrative Safeguards:** periodic evaluation and incident response	reviewing them, investigate suspicious activity, retain review records and periodically test the monitoring process.
R3: Missing BAA	**Requirement 12:** Support information security with organizational policies; also address PCI third-party responsibilities and security assessments	**Administrative Safeguards:** business-associate management	Identify every vendor that accesses regulated data, review vendor agreements, execute the required BAA, define permitted uses and disclosures of PHI, and assess the vendor's security controls.
R4: Incomplete scope	Determine where cardholder data is stored, processed or transmitted and identify the complete Cardholder Data Environment	**Administrative Safeguards:** risk analysis and risk management.	Conduct a documented scope assessment covering business processes, data flows, systems, users and third parties. Maintain separate PCI DSS and HIPAA scopes while identifying overlapping systems.
R5: Unclear incident response	**Requirement 12:** Maintain organizational security policies. **Requirement 11:** Test security systems and processes.	**Administrative Safeguards:** incident response, contingency planning and periodic evaluation.	Document incident roles, escalation procedures and recovery activities; train responsible employees; conduct

			an incident-response exercise; and record lessons and corrective actions.
R6: Lost laptop containing ePHI	**Requirement 9:** Restrict physical access to cardholder data.	Physical Safeguards and Technical Safeguards	Use facility and device controls, workstation security, media-management procedures, access controls and technical protection that reduces the impact of device loss.
R7: Unprotected payment account data	**Requirement 3:** Protect stored account data **Requirement 4:** Protect account data with strong cryptography during transmission	N/A	Minimize stored payment information and protect stored and transmitted account data using appropriate cryptographic controls.
R8: Policies not followed	**Requirement 12:** Maintain organizational security policies.	Administrative Safeguards	Establish the complete control chain: policy, procedure, responsible owner, implementation, evidence and testing. Provide security-awareness training and periodically evaluate compliance.

Evidence Plan: What Proves the Controls Work

Nexus should determine whether the evidence shows that controls are both designed appropriately and operating effectively. Evidence should therefore show:

- The control is documented in a policy and procedure.
- A responsible owner has been assigned.
- The control has been implemented.
- Implementation records are available.
- The control has been tested.
- Identified weaknesses have been corrected and monitored.

Table 5: Evidence Plan

Control Area	Evidence requested	Control Owner	How evidence proves effectiveness
Strong authentication	Access reports showing authorized users and authentication controls; authentication configuration records; evidence that MFA is enabled.	IT/Security	Demonstrates that authentication has been implemented and that access is limited to identified users
Log monitoring	Completed log-review records, monitoring reports and records showing that identified issues were investigated.	Security Operations Centre (SOC)	Demonstrates that logs are not merely collected but are actively reviewed and used to identify suspicious activity

Vendor management	Signed Business Associate Agreement, reviewed vendor agreement, vendor security-assessment records and documented responsibilities.	Legal/GRC	Demonstrates that permitted PHI uses, disclosures and safeguarding responsibilities have been formally established
Compliance scoping	Approved scope document, process inventory, data map and records identifying vendors with access to regulated information.	GRC	Demonstrates that Nexus has identified where cardholder data and PHI/ePHI are stored, processed, received, maintained, or transmitted.
Incident response	Approved incident-response plan, completed exercise report and documented corrective actions	Security	Demonstrates that Nexus has tested the response process and that responsible employees understand their roles.
Physical and device security	Device-control records, workstation-security procedures, physical-access records and evidence of secure media disposal.	IT/Security and Facilities	Demonstrates that Nexus tracks devices, limits physical access, protects workstations and securely manages or disposes of media containing ePHI.
Stored and transmitted data protection	Configuration records showing stored account data is protected, and strong cryptography is used	IT/Security	Demonstrates that technical safeguards have been implemented to protect regulated

	when data moves across networks.		information at rest and in transit, rather than existing only as policy statements
Security awareness	Training records, attendance or completion records, approved procedures and periodic evaluation results.	GRC and department managers	Demonstrates that employees received required training and that Nexus periodically evaluates whether its policies and procedures are understood and followed.

Prioritized Remediation Plan

The remediation plan follows the GRC sequence of **identify, assess, prioritize, remediate, test and monitor**. The order below prioritizes controls that prevent unauthorized access and improve detection, followed by vendor, scope and response weaknesses.

Table 6: Remediation Plan

Priority	Gap	Remediation Action	Completion Evidence	Rationale
1 – Immediate	Weak authentication	Strengthen authentication, implement MFA and ensure access is based on business need-to-know.	Access reports and authentication records.	Stronger authentication is critical; a stolen password can affect access controls, authentication, logging, monitoring, and incident response.
2 – Immediate	Poor log review	Establish a formal log-review and monitoring process, assign SOC responsibility and investigate identified anomalies.	Completed review records and monitoring reports.	Security logs provide limited protection if no one reviews them; this weakness delays detection and increases business risk.
3 – High	Missing BAA	Review the healthcare vendor agreement and execute the required Business Associate Agreement.	Signed BAA and vendor-review records.	The BAA formally establishes permitted and required uses and disclosures of PHI and the parties' obligations.
4 – High	Compliance scoping	Conduct a complete scope assessment covering business	Approved scope document and data map.	Nexus cannot demonstrate adequate protection without identifying

		processes, regulated data, systems and third parties.		where cardholder data and PHI/ePHI exist and which vendors can access them.
5 – High	Incident response	Document the incident-response plan, define responsibilities and conduct an exercise.	Completed exercise report and updated incident-response plan.	Testing shows whether the process works in practice rather than existing only as a document.
6 – High	Physical and device security	Maintain a device inventory; strengthen workstation and device security; restrict facility access; implement visitor controls; establish secure media disposal procedures.	Device inventory, physical-access records, visitor logs, workstation-security records and media-disposal certificates	Physical loss can lead to unauthorized disclosure even when network controls exist.
7 – High	Stored and transmitted data protection	Protect stored account data and apply strong cryptography when payment data moves across networks; implement appropriate technical protections for ePHI.	Encryption configuration records, data-protection test results and approved security standards.	Nexus stores, processes and transmits cardholder data and handles ePHI, making data protection central to both PCI DSS and HIPAA compliance.

8 – High	Security awareness	Deliver role-based security and privacy training; communicate acceptable practices; track completion; periodically evaluate employee understanding and compliance.	Training materials, completion records, attendance reports and evaluation results.	A security policy is ineffective if employees do not understand or follow it; security must remain everyone's responsibility.

The Management Message: Top Three Risks Explained

Risk 1. Weak Authentication Controls: *Anyone with a stolen password can reach our payment and patient systems.*
Privileged access is not protected by multi-factor authentication. One phished credential could expose cardholder data and patient records at the same time. PCI DSS requires MFA for all access into the cardholder data environment, every user, every role, every path, so this is a live non-compliance, not a best-practice aspiration (Savage, 2026).

Risk 2. Lack of Log Review: *We collect security logs that nobody reviews, so a breach could go undetected for months.*
Logs exist but are not reviewed, which delays detection of unauthorized activity. PCI DSS now requires automated daily review of security and CDE logs (Secure60, n.d.), and HIPAA requires mechanisms that both record and examine activity in systems holding ePHI (Alder, 2026). This compounds Risk 1 directly: HIPAA's 60-day individual notification clock starts when the breach is discovered, and where discovery took months, OCR examines whether that delay was itself a Security Rule violation caused by insufficient audit controls.

Risk 3. Missing Business Associate Agreements (BAAs): *A vendor is handling patient information without a signed Business Associate Agreement.*
When a hospital sends patient billing data to Nexus and Nexus passes it to a cloud provider, every link in that chain needs written assurances of safeguards. Alder (2026) explains that HIPAA permits a business associate to use a subcontractor only after obtaining satisfactory assurances documented in a written contract. Without it, Nexus carries full accountability for a partner it cannot contractually control, and this is the easiest of the three findings for a regulator to prove, because it is either signed or it is not.

Our immediate plan:

- Enforce MFA and privileged-access controls (PCI Req. 8; HIPAA Technical Safeguards)
- Implement daily/weekly log review with documented evidence (PCI Req. 10; HIPAA Audit Controls)
- Complete the BAA review and ensure that all vendors handling PHI are contractually compliant.

These three actions will significantly reduce financial, legal, and reputational risk.

References

1. Bello-Abubakar, A. (n.d.). *Enterprise PCI DSS 4.0 & HIPAA: GRC C26-07, Class 5* [Course presentation]. 10Alytics.
2. Savage, V. (2026, July 15). *PCI DSS MFA Requirements*. LoginTC. https://www.logintc.com/mfa-compliance/pci-dss/
3. Secure60. (n.d.). *PCI DSS Requirement 10 Logging and Daily Review.* Retrieved from https://www.secure60.io/compliance/controls/pci-dss-requirement-10/
4. Alder, S. (2026, January 5). *HIPAA business associate agreement (BAA) requirements. HIPAA Journal.* ***https://www.hipaajournal.com/hipaa-business-associate-agreement/***
5. Alder, S. (2026, January 12). *HIPAA breach notification requirements*. HIPAA Journal. https://www.hipaajournal.com/hipaa-breach-notification-requirements/